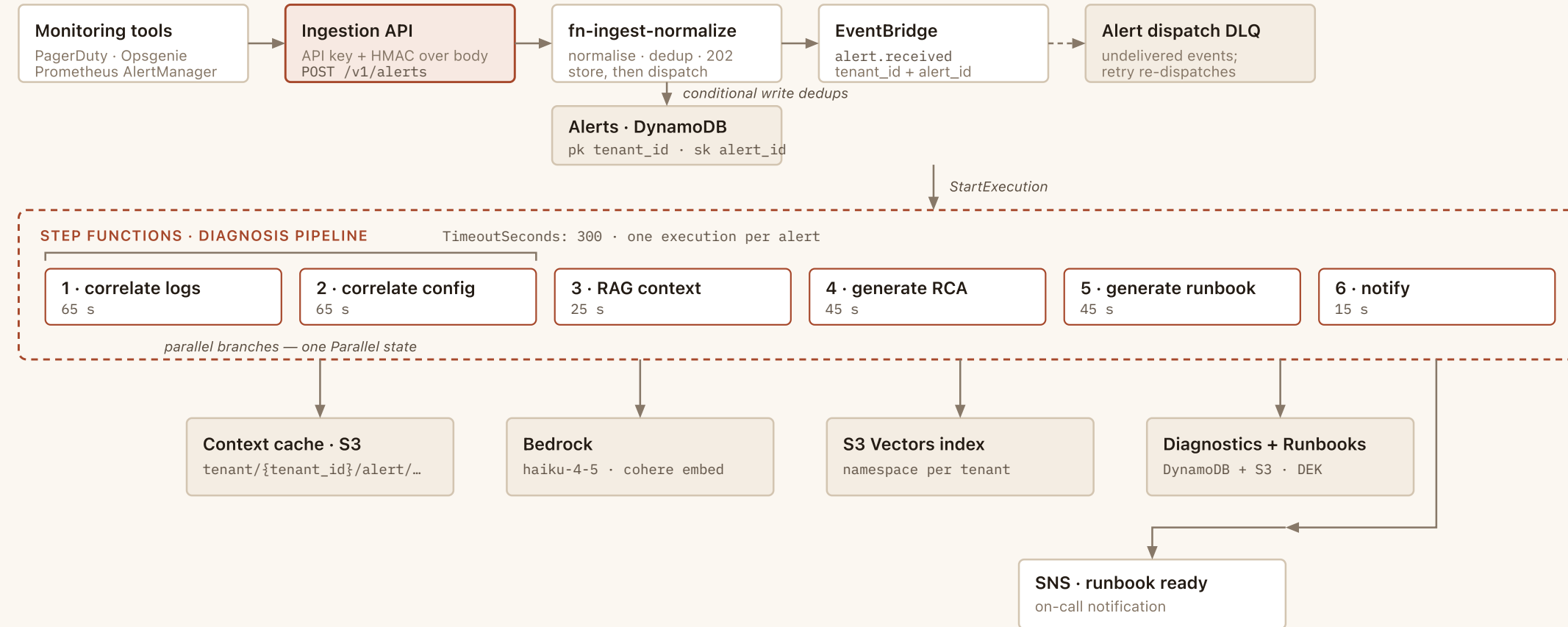


Arcadia

Automated Root Cause Analysis & Diagnostic Incident Assistant

ARCHITECTURE · WRITE PATH · FR-01-07 · NFR-02

Alert to runbook, unattended



One CloudFormation stack in ap-southeast-1. The dashed edge is the failure path: an event EventBridge cannot deliver lands on the dispatch DLQ rather than being lost. The alert row is written before dispatch, and a delivery stored but not dispatched is answered 5xx so the sender retries.

FUNCTIONAL SCOPE · FR-01 → FR-11 — EVERY ROW TRACES TO A NAMED FILE; NOTHING ASPIRATIONAL

Eleven requirements, and where each one lives

ID	CAPABILITY	IMPLEMENTED BY	STATE
FR-01	Ingest alerts from an alert-management system	POST /v1/alerts on the ingestion API → fn-ingest-normalize	Built
FR-02	Correlate the alert with logs from the log platform	fn-correlate-logs, cached to the context-cache bucket	Built
FR-03	Detect config/deploy changes preceding the outage	fn-correlate-config, parallel branch of the same state	Built
FR-04	Generate root cause analysis	fn-generate-rca - Claude Haiku 4.5, RAG-grounded	Built
FR-05	Generate prioritised remediation recommendations	Same call: structured P1/P2/P3 steps with commands	Built
FR-06	Generate a human-readable runbook with executable steps	fn-generate-runbook → Markdown in the runbooks bucket	Built
FR-07	Deliver the runbook within 5 minutes of the alert	State-machine TimeoutSeconds: 300 + SLA alarms	Built
FR-08	Multi-tenant isolation	Partition key + S3 prefix + STS session tag + per-tenant DEK	Built
FR-09	Audit trail of executed remediation actions	fn-audit-write → AuditTrail table, 6-month TTL	Built
FR-10	View diagnostics, recommendations and runbooks via UI or API	Admin REST API + the console on CloudFront	Built
FR-11	Runbook export / execution via API	GET /v1/runbooks/{id}/export; execution gated on approval	Built

01 · PROBLEM · OBJ-01-03 · DOCS/PROBLEM_STATEMENT.MD, APPROVED 2025-01-18

Triage is four manual lookups before anyone touches the fix

When production breaks, the on-call engineer reads the alert, then goes hunting: the log platform (ELK + Splunk + Datadog), the deploy history (Git + Terraform + Ansible), the commit that landed an hour ago, and the memory of whoever handled it last time (wikis, tickets, memory). Four serial lookups sit between the alert and the first remediation step — each a different system, query language and set of credentials. Arcadia does not replace them; it queries all three read paths on the engineer's behalf and hands back a written diagnosis.

- Time — investigation happens before remediation, so every minute of it is downtime.
- Consistency — two engineers given the same alert produce different diagnoses and different fixes.
- Knowledge loss — last quarter's identical incident was resolved, written up, then never consulted again.

THE VOLUME IT HAPPENS AT	
Alerts	100–500 per day, 1,000+ in a major incident
Application logs	10–100 GB per day, per tenant
Config changes	10–100 per day, across VCS and deploys
Runbooks	50–100 per week, 200+ in an outage window

02 · OBJECTIVES · OBJ-1 · SC — THE APPROVED BRD'S TARGETS, NOT RESTATED AMBITIONS

Three objectives, three measurable criteria

ID	OBJECTIVE	PRIORITY
OBJ-01	Reduce mean time to resolution for technical outages	Must
OBJ-02	Minimise manual administrator effort during investigation and remediation	Must
OBJ-03	Improve consistency and repeatability of diagnosis across incidents	Should
ID	SUCCESS CRITERION	TARGET
SC-01	Average incident resolution time, against the tenant's pre-rollout MTTR	~50%
SC-02	Manual trigger time per incident — the three read paths above	~60%
SC-03	Alert triage → generated runbook. Enforced as TimeoutSeconds: 300, not 1min alarmed after the fact	< 5 min

Only SC-03 is something software can prove on its own; the first two are measured against the tenant's own MTTR history after rollout.

PRIMARY STAKEHOLDERS	
Sysadmins & operations engineers	Faster diagnosis, clearer steps
Incident management leadership	Lower MTTR, SLA visibility
Platform / infrastructure owners	Uptime, incident insight

03 · USERS · FR-08 · FR-10 · NFR-04 — ROLES MAP 1:1 ONTO COGNITO GROUPS IN TEMPLATE.YAML

Three roles, deliberately unequal

Every user belongs to exactly one tenant and holds exactly one role. The split is not cosmetic: it is what makes the approval gate meaningful, because exactly one role can authorize a change to live infrastructure.

COGNITO GROUP	WHO, AND WHAT THEY MAY DO	CONCURRENT
TenantAdmin	First person to sign up from an email domain. Sees everything, manages team and integrations, only role that can approve remediation. Cannot be demoted if last remaining admin.	5–50
TenantEngineer	Everyone who signs up afterwards. Works incidents: reads diagnoses and runbooks, raises incidents by hand, cannot approve. Promoted to admin only by an admin.	5–50
TenantLeadership	Accountable, not operating. Cross-incident overview, audit trail, team list — and deliberately cannot raise or approve anything. Assigned by an admin.	2–10
SCALE THE DESIGN IS SIZED FOR		
Concurrent diagnostic sessions	2–5 baseline; 10–20 during multi-tenant incidents	
Alert volume growth	+50% over 12 months, without re-architecture	
WHY TENANCY IS NOT A SIGNUP FIELD		
The BRD expects OAuth/SAML per tenant. With self-signup, a writable custom:tenant_id would let anyone claim an existing tenant's id and read its incidents — and every control below that point would faithfully scope access to whatever the token claimed. So tenancy is derived server-side, once, from the verified email domain.		

04 · BOUNDARIES · C-01 → C-05 — C-03 SHAPES THE PRODUCT MOST

Constraints that shaped the design

- C-01 Zero cross-tenant visibility. Pooled security is allowed; leakage is not. Answered by defence in depth rather than one check.
- C-02 Config data may be unavailable. A diagnosis missing change history must say so rather than imply confidence it has not earned.
- C-03 Remediation is a recommendation. Human approval is required before anything executes. This is the reason the approval gate exists at all.
- C-04 Correlation needs timestamp and service alignment across systems that do not agree on either.
- C-05 Log query speed is the customer's. Their platform's latency and retention bound NFR-05, not ours.

EXPLICITLY OUT OF SCOPE	
Infrastructure provisioning or deployment orchestration	
Predictive outage prevention and anomaly detection	
Automatic remediation with no human approval — excluded by C-03, not by effort	
Integrations beyond the live scheduling systems	
SLA management, on-call planning, escalation workflow	
Executive dashboards and post-incident trend analytics	
Per-tenant custom runbook templates — standardised only	
THE CONSEQUENCE OF C-03	
Arcadia is not an auto-remediation system, and is not trying to be. It compresses the diagnosis, then stops at a gate that exactly one human role can open. Everything downstream of that gate — the platform call, the IMS update, the audit record — exists to make opening it safe and reviewable.	

OUTPUT SHARE, NOT FREE TEXT	
The RCA call returns a one-sentence cause, reasoning, a confidence value, a model version, and remediation steps as P1/P2/P3 objects each with text and an optional command. The console renders that structure; it does not parse prose.	
C-02: SURFACED RATHER THAN HIDDEN	
Config history is optional — some tenants have no VCS integration. A diagnosis produced without it is marked as partial-evidence and its confidence is downgraded, because a diagnosis that silently omits change history implies confidence it has not earned.	

A multi-tenant serverless assistant that turns a raw monitoring alert into a triaged incident with a proposed root cause and an approvable remediation runbook — inside five minutes, without ever executing a change on its own.

5 min

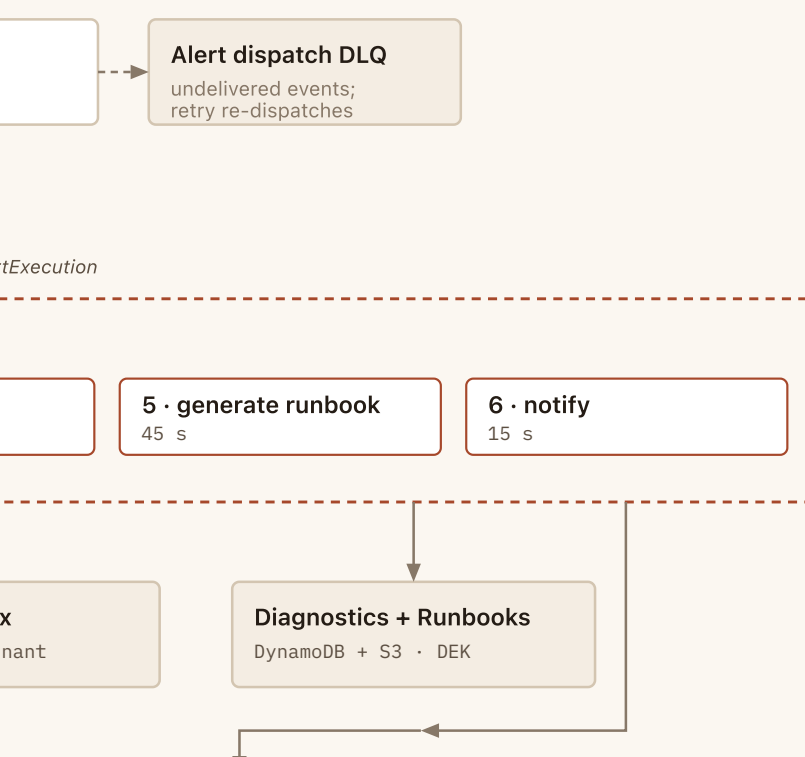
ALERT → RUNBOOK SLA

AWS SAM · Python 3.13 Lambda · Step Functions · Bedrock · global.anthropic.claude-haiku-4-5-20251001-v1:0 · [cohere.embed-multilingual-v3 · S3 Vectors · DynamoDB · Cognito · CloudFront · one stack, [app-b9dac5ac-bc8bf47-triage, ap-southeast-1]

LAMBDA FUNCTIONS · AUTOMATED TESTS · FR5 BUILT · TENANT ROLES · CROSS-TENANT PATHS

ARCHITECTURE · READ PATH · FR-10 · FR-11

Console to approval



No hosted UI and no SDK: the page calls Cognito's SignUp and InitiateAuth directly and styles the form itself. A 401 triggers one silent REFRESH_TOKEN_AUTH and a retry before the session is treated as expired. Dashed edges are best-effort paths that must never block the request they belong to.

NON-FUNCTIONAL · NFR-01 → NFR-08 — A TARGET WITH NO MECHANISM IS A WISH

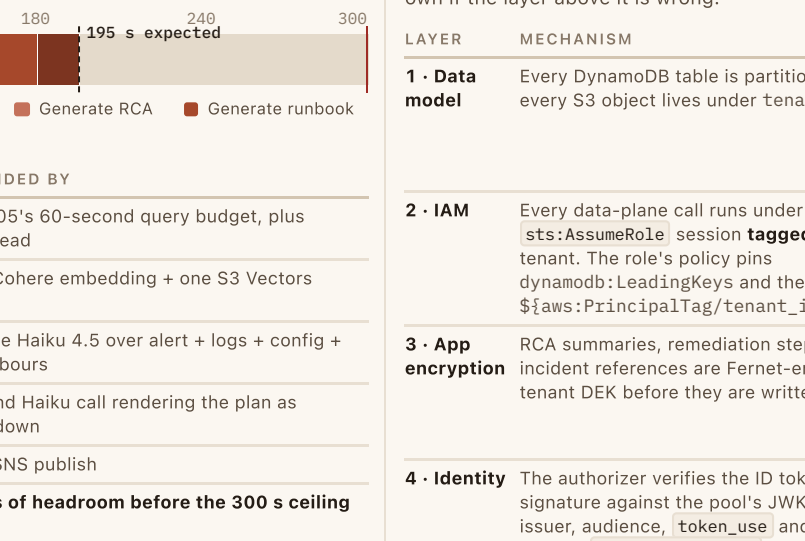
Eight targets, and what actually enforces them

ID	REQUIREMENT	TARGET	ENFORCED BY
NFR-01	Runbook generation latency	< 5 min	State machine TimeoutSeconds: 300; per-attempt timeouts sum to ~195 s; RunbookSLAAlarm
NFR-02	Alert ingestion latency	< 1 min	Synchronous write + EventBridge dispatch inside the request; IngestionSLAAlarm
NFR-03	System availability	99.5%	No VPC-bound compute; every component is an AWS-managed regional service
NFR-04	Concurrent diagnostic sessions	20+	One Step Functions execution per alert; Lambda concurrency, not a shared worker pool
NFR-05	Log/config query performance	< 60 s	Per-attempt task timeout of 65 s on both correlation branches, run in parallel
NFR-06	API response time	< 2 s	Single-partition DynamoDB reads; runbook bodies served as presigned S3 GETs
NFR-07	Tenant data isolation	Zero leakage	Four independent layers (below), TLS in transit, SSE + app-layer DEK at rest
NFR-08	Scalability	+50% in 12 mo	On-demand DynamoDB, serverless throughput; no capacity to re-plan
STATED HONESTLY			
NFR-03's 99.5% and SC-01/SC-02's reduction targets cannot be demonstrated by a prototype in a hackathon window — they need production traffic and a tenant's own MTTR baseline. What is demonstrable today is NFR-01, NFR-05, NFR-06 and NFR-07 , all enforced structurally and covered by tests.			

05 · THE BUDGET · NFR-01 · SC-03 — THE FIVE-MINUTE PROMISE, SPENT EXPLICITLY

Five minutes, allocated stage by stage

A latency target only alarmed after the fact is a report, not a guarantee. Each stage carries its own per-attempt timeout, and the state machine carries a 300-second ceiling that kills the execution outright.



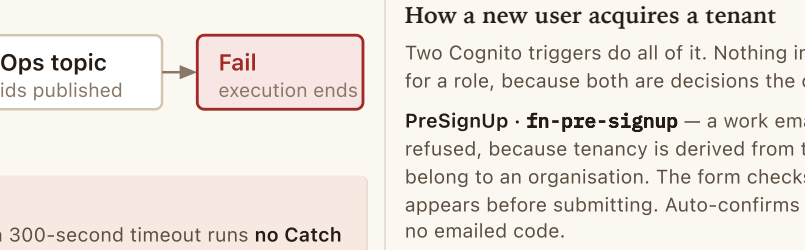
Bar spans are the per-attempt task timeouts from state-machine/diagnosis_pipeline.asl.json, laid on the 300-second budget the state machine enforces. The two correlation branches run concurrently, so they cost 65 seconds once, not twice.

06 · ORCHESTRATION · DIAGNOSIS_PIPELINE.ASL.JSON — 10 STATES, ONE PARALLEL, ONE FAIL

What happens when a stage fails

Every stage retries with exponential backoff, then routes to a single failure path that marks the alert, preserves the whole execution state, and tells ops which identifies to look at. Silence is never an outcome.

STATE	TYPE	TIMEOUT ON ERROR
CorrelateContext	Parallel	65 s Catch → MarkAlertFailed
MergeCorrelation	Pass	—
BuildRagContext	Task	25 s Retry x1, then Catch
GenerateRca	Task	45 s Retry x2, then Catch
GenerateRunbook	Task	45 s Retry x2, then Catch
NotifyRunbookReady	Task	15 s Retry x1, then Catch



THE CASE A CATCH CANNOT HANDLE

An execution killed by the state machine's own 300-second timeout runs no Catch at all — so TIMEOUT_OUT and AbortError executions are picked up by a separate EventBridge rule and marked failed from outside the execution. Without it, an SLA breach would leave an alert sitting in processing forever, which reads as "still working" rather than "gave up".

PROGRESS REPORTING	
Each task marks its own stage on the alert row as its first action, so the console can draw a live timeline. It is advisory by design: a failure to record progress must never fail the stage that is reporting it.	

07 · INGESTION · FR-01 · NFR-02 — TWO WAYS IN, TWO TRUST MODELS

Two front doors, and why they trust different things

Public webhook POST /v2/alerts ingestion API	API key on a usage plan gates the endpoint; HMAC over the raw request body, signed with that tenant's secret from Parameter Store. Only after both pass is the tenant_id inside the payload trusted. A signature failure writes nothing to the Alerts table. Duplicate alert_id is dropped by a conditional write, not a read-then-write race. Returns 202 once stored and dispatched.
Authenticated console POST /v1/alerts admin API	Takes the tenant from the authorizer context and ignores any tenant_id in the body — otherwise a signed-in user of one tenant could write an incident into another. Requires the create_incident capability, so leadership cannot raise one. Records source: console so the overview can let hand-raised incidents from machine ones. Everything after validation is shared with the webhook through one module, so both produce the same row and start the same pipeline.

STORE, THEN DISPATCH — AND MEAN IT	
The alert row is written before the EventBridge dispatch. If the write succeeds and the dispatch does not, the request is answered with a 5xx rather than acknowledged, and the sender's retry re-dispatches the stored alert instead of creating a second one. Acknowledging a stored-but-undispatched alert is the failure mode that looks fine from the outside and never produces a runbook — an UndispatchedAlertsSLAAlarm watches for it as well.	

08 · THE AI LAYER · FR-04-06 — GROUNDING IS THE DIFFERENCE BETWEEN A PLAUSIBLE ANSWER AND A USABLE ONE

The model never sees the alert alone

A language model handed only "check-out-api 5xx rate above threshold" can write a confident, generic, useless paragraph. Three retrieval steps run first, and the diagnosis is prompted with all of them.

- Correlate — the tenant's log platform and VCS/deploy history are queried with the tenant's own credentials, in parallel, and cached to S3 under the tenant prefix.
- Embed — alert x logs x config are embedded with cohere.embed-multilingual-v3, invoked with its bare model id directly in ap-southeast-1.
- Retrieve — that vector queries the tenant's own namespace in the S3 Vectors index, returning similar past incidents and how they were actually resolved.
- Generate — Claude Haiku 4.5 is prompted with alert, correlated signals and retrieved neighbours, and returns a root-cause summary plus prioritised steps.

MODEL ID, EXACTLY AS INVOKED	USED FOR
global.anthropic.claude-haiku-4-5-20251001-v1:0	RCA, remediation plan, runbook drafting
cohere.embed-multilingual-v3	Embeddings for retrieval

The global_inference-profile prefix on Haiku is not decoration — a bare model id fails at runtime with "on-demand throughput isn't supported", inside the deployed application where it is hardest to diagnose. Cohere is the one local model and takes no prefix.

DECLINE IS A DECISION TOO	
There is a real POST /v1/runbooks/{id}/decline. A decline is recorded and audited, not a UI-only state that vanishes on reload — "we looked and chose not to" is exactly the kind of thing an incident review needs to see.	

11 11

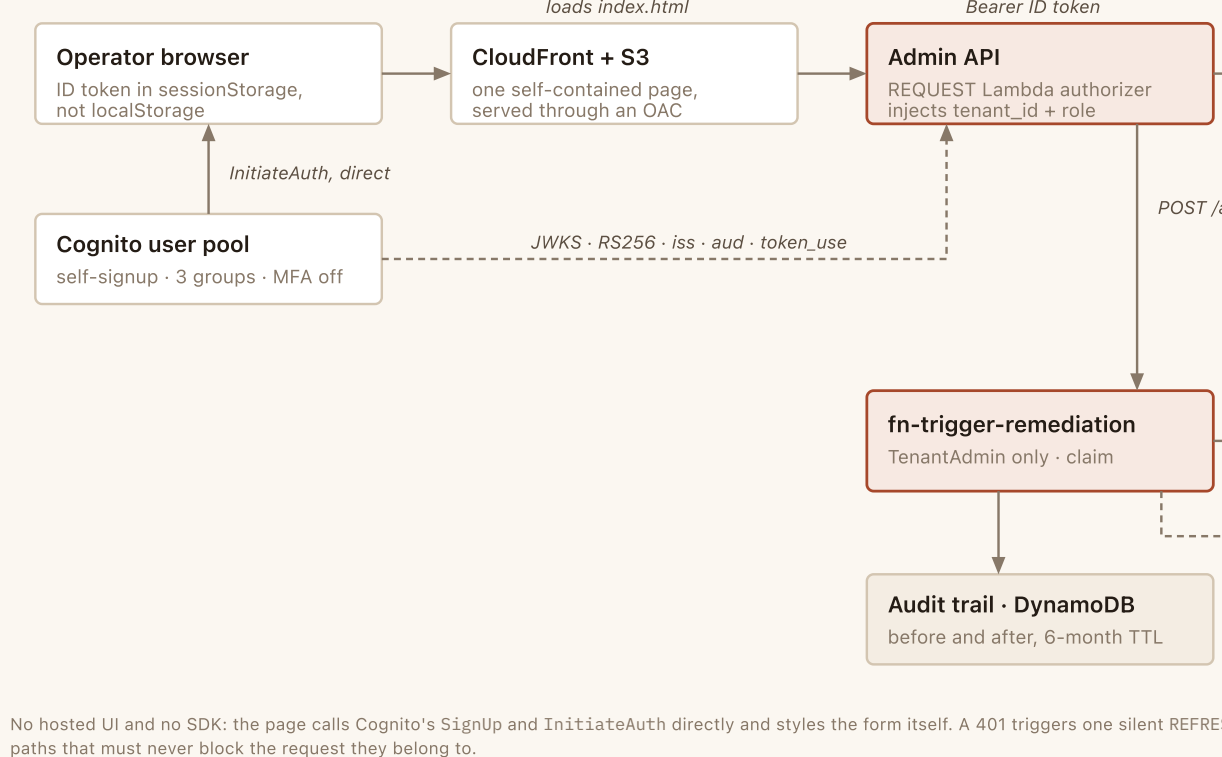
FR5 BUILT

TENANT ROLES

CROSS-TENANT PATHS

ARCHITECTURE · READ PATH · FR-10 · FR-11

Console to approval



No hosted UI and no SDK: the page calls Cognito's SignUp and InitiateAuth directly and styles the form itself. A 401 triggers one silent REFRESH_TOKEN_AUTH and a retry before the session is treated as expired. Dashed edges are best-effort paths that must never block the request they belong to.

13 · THE CONSOLE · FR-10 · NFR-06 — ONE SELF-CONTAINED PAGE ON CLOUDFRONT, NO FRAMEWORK, NO BUILD STEP

Five sections, and one that matters most

ID	INCIDENTS	DETAILS
01	Overview	The tenant's incidents, newest first, with severity, service and pipeline state. Everyone sees it — that is what belonging to a tenant means.
02	New incident	Raise one by hand at SEV1-SEV4. Starts the same pipeline as a webhook alert, recorded as console.
03	Overview	Cross-incident view for admin and leadership, joined in the browser from two endpoints that already existed — no new backend aggregation.
04	Team	Who is in the tenant and their role. The only path to TenantLeadership, and the only place a role changes.
05	Audit trail	Append-only records of executed and refused remediation, with actor, action, target and result.
Incident detail — the live timeline		A five-minute wait cannot be a spinner. Six named stages with glyph and state, an elapsed clock, and a budget bar against the 300-second SLA.
THE SLA FIGURE IS REAL		
The overview's SLA number is the actual NFR-01 measurement: time from alert arriving to runbook ready, against the five-minute budget. An incident with no runbook counts as pending inside the budget and breached once past it — so a pipeline that silently stopped shows up, rather than being omitted for having nothing to measure.		
HOW IT IS BUILT		
One HTML file. The shared logic in lib/triage.mjs is inlined into it, and the deploy fails if the inlined copy has drifted.		
Colour, type and spacing come from design/zeference.html; a test compares the two token sets so they cannot silently diverge.		
Tokens in sessionStorage, so a bearer token does not outlive the tab that obtained it.		
Severity is never colour-only — every state pairs a glyph and a word with its tone.		

14 · INTEGRATIONS · FR-02 · FR-03 · FR-11 — TENANT-SUPPLIED URLS ARE ATTACKER-CONTROLLED INPUT TO A FUNCTION HOLDING CREDENTIALS

Four outbound integrations, one guard

INTEGRATION	DIRECTION	USED AT
Log aggregation	Pull	Correlation stage
VCS / deploys	Pull	Correlation stage
Remediation platform	Push	After approval
Incident management	Push	After execution, async

GET / PUT / DELETE /v1/integrations, restricted to TenantAdmin and audited. API keys are write-only: a return reads the endpoint and a boolean for whether a key is set — never the key.

- THE GUARD, IN TWO HALVES
- Every outbound call goes through one module: https only, the resolved address must be public, redirects are refused, the response is base-64-encoded.
- assert_target_shape judges what a URL shows on its own — scheme, and a literal IP. This is what the settings API validates a stored endpoint against.
- The full check adds resolution and runs on every call — because a hostname that resolves publicly at write time can be repointed afterwards.

THE WINDOW THAT REMAINS

The guard resolves a hostname and checks the address, then the HTTP client resolves again. A DNS record that changes in between is not caught. Closing it means pinning the checked address and carrying the hostname for TLS verification by hand — acceptable at prototype scale, and documented rather than left implicit.

15 · INVENTORY · ONE SAM TEMPLATE, ONE STACK, ONE REGION

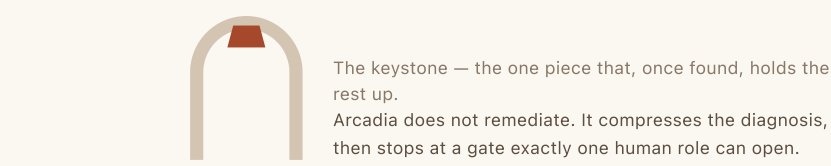
What actually gets deployed

# RESOURCE	NOTES
2 Lambda functions	Python 3.13, one shared layer for config, tenant-scoped clients, crypto, Bedrock, RBAC, audit
2 REST APIs	Ingestion (API key + HMAC), admin (REQUEST authorizer)
1 State machine	10 states, 300-second ceiling
5 DynamoDB tables	Tenants, Alerts, Diagnostics, Runbooks, AuditTrail — all tenant_id-partitioned
4 S3 buckets	Context cache, runbooks, audit exports, console — plus the S3 Vectors bucket
3 SQS queues	Alert-dispatch DLQ, pipeline-failure DLQ, audit-write DLQ
3 SNS topics	Runbook ready, ops alarms, vector-store setup
6 CloudWatch alarms	Runbook SLA, SLA timeout, ingestion SLA, ingestion errors, undispached alerts, audit-write failure
3 IAM roles	Including TenantScopedRole; all carry the deploy permissions boundary
19 Log groups	Explicit, so retention is a decision rather than a default

API SURFACE	WHAT IT DOES
POST /v1/alerts (both APIs)	
GET /v1/alerts	
GET /v1/alerts/{alertId}/status	
GET /v1/diagnostics/{alertId}	
GET /v1/runbooks	
GET /v1/runbooks/{runbookId}	
GET /v1/runbooks/{runbookId}/export	
POST /v1/runbooks/{runbookId}/approve	
POST /v1/runbooks/{runbookId}/decline	
GET /v1/audit	
GET /v1/team	
POST /v1/team/{userId}/role	
GET /v1/integrations	
PUT /v1/integrations/{integration}	
DELETE /v1/integrations/{integration}	

ONE NAME, EVERYWHERE

Every physical name — tables, buckets, queues, topics, functions, roles, log groups, alarms, the state machine, both APIs, the user pool and every per-tenant parameter path — derives from a single NamePrefix parameter. A test fails if any name spells the prefix out instead, if the scripts and the template disagree, if the runtime constant drifts (that one fails as AccessDenied at runtime, not at deploy time), or if the prefix pushes a name past its AWS length limit.



The keystone — the one piece that, once found, holds the rest up. Arcadia does not remediate. It compresses the diagnosis, then stops at a gate exactly one human role can open.